CHECKLIST · SHOPIFY APP

Shopify App Requirements Checklist (2026)

The 2026 Shopify App Store requirements checklist — Customer Privacy API, managed install, token exchange, and the review gates a listing must pass.

A comprehensive, downloadable checklist for building, submitting, and maintaining a Shopify App Store app. Based on Shopify's official App Store requirements and the latest platform changes through May 2026.

How to Use

Copy this file into your project and check off items as you complete them. Items marked **(mandatory)** will block your App Store submission if unmet. Items marked **(recommended)** are best practices that improve approval odds and app quality.

---

1. Dev Dashboard & Project Setup

1.1 Organization & Access

- ☐ **Create app in Dev Dashboard** — dev.shopify.com, not the legacy Partner Dashboard **(mandatory)**

☐ **Set up RBAC roles** — assign Organization Owner + Admins; use system roles or create custom roles (March 2026+)

☐ **Create dev store** — use Dev Dashboard to create a dev store on the plan tier you need (any plan including Plus)

☐ **Install Shopify CLI 3.84.1+** — required for CLI-managed extensions and `shopify app deploy`

1.2 App Configuration (TOML)

☐ `shopify.app.toml` **has correct** `client_id` — from Dev Dashboard > App > Settings

☐ `application_url` **set** — your app's primary URL (must not contain "Shopify" or "Example")

☐ `embedded = true` — if your app renders in Shopify Admin (most apps)

☐ `[access_scopes]` **lists only required scopes** — Shopify reviews for unnecessary scopes (Feb 2025+) **(mandatory)**

☐ `use_legacy_install_flow = false` — or omit entirely; use Shopify managed installation

☐ `[auth] redirect_urls` **configured** — OAuth callback URLs for your worker/app

☐ `[webhooks] api_version` **set** — use a supported API version (e.g., `2026-07`)

☐ **Compliance webhooks declared** — `customers/data_request`, `customers/redact`, `shop/redact` **(mandatory)**

1.3 Extensions

☐ **All extensions managed via CLI** — dashboard-managed extensions are deprecated; use `shopify app deploy`

☐ **Extensions have** `uid` **identifiers** — run `shopify app deploy` after migration to assign UIDs

☐ `.env` **files map extension handles** — `SHOPIFY_<HANDLE_SNAKE_CASE>_ID` for each extension

2. Authentication & Tokens

2.1 OAuth Installation Flow

- ☐ **OAuth initiates immediately on install** — no UI interaction before OAuth handshake **(mandatory)**
- ☐ **OAuth initiates immediately on reinstall** — even if merchant previously uninstalled **(mandatory)**
- ☐ **Redirect to app UI after OAuth** — not to a blank page or external site **(mandatory)**
- ☐ **Installation starts from Shopify-owned surface** — do not ask merchants to manually enter `.myshopify.com` URLs **(mandatory)**
- ☐ **Test OAuth on a fresh dev store** — verify install → approve → redirect works cleanly

2.2 Expiring Offline Tokens (April 1, 2026+)

- ☐ **Send `expiring=1` in token exchange** — required for all new public apps **(mandatory)**
- ☐ **Store `access_token` (60-min TTL)** — `shpua_` prefix
- ☐ **Store `refresh_token` (90-day TTL)** — `shprt_` prefix; encrypt at rest
- ☐ **Store `expires_in` / compute `expires_at`** — track token expiry
- ☐ **Implement proactive token refresh** — refresh 5 minutes before expiry, not after 401
- ☐ **Handle 401 as fallback refresh trigger** — in case proactive refresh fails
- ☐ **Update stored tokens on every refresh** — both access token and new refresh token

- [ ] **Monitor refresh failures** — log and alert; fall back to new OAuth authorization if refresh token expires
- [ ] **Remove assumptions that tokens never expire** — audit all code paths that use the admin token

2.3 Session Tokens (Embedded Apps)

- [ ] **Use session tokens for authentication** — not third-party cookies or localStorage **(mandatory)**
- [ ] **App works in Chrome incognito** — verify no dependency on cookies for embedded context **(mandatory)**
- [ ] **Session tokens are short-lived** — do not cache or persist; fetch fresh token per request

---

3. Security & User Data Scoping

3.1 Access Scopes

- [ ] **Request minimum scopes needed** — Shopify removes unnecessary scopes on review **(mandatory)**
- [ ] **Document why each scope is needed** — be prepared to justify during review
- [ ] **Handle redacted fields gracefully** — unapproved fields return `null`, not errors
- [ ] **No deprecated or legacy scope usage** — check against current API version

3.2 Protected Customer Data

LEVEL	ACCESS	YOUR ACTION
0	No customer data	No action required
1	Customer data excluding name/email/phone/address	Request in Partner Dashboard + implement Level 1 requirements
2	Customer data including name/email/phone/address	Request + Level 1 & 2 requirements + data protection review

- ☐ **Determine your data level** — most CRM/sync apps are Level 2
- ☐ **Request protected customer data access** — Partner Dashboard > App > API access > Protected customer data
- ☐ **Request specific field access** — `read_customer_name`, `read_customer_email`, `read_customer_phone`, `read_customer_address` as needed
- ☐ **Complete Data Protection details** — required for Level 2 review
- ☐ **Handle null for unapproved fields** — API returns `null` with error message for redacted fields
- ☐ **Test on non-development store** — dev stores always have access; production enforces scoping

3.3 Data Security

- ☐ **Encrypt tokens at rest** — access tokens, refresh tokens, API keys
- ☐ **Never expose secrets in client-side code** — no tokens in HTML, JS, or frontend bundles
- ☐ **HTTPS everywhere** — all OAuth redirects, webhooks, and API calls over TLS
- ☐ **Validate webhook HMAC signatures** — return 401 for invalid Shopify HMAC headers **(mandatory)**
- ☐ **Secrets stored securely** — use environment secrets (e.g., `wrangler secret put`), not config files

- [ ] **No sensitive data in logs** — mask tokens, passwords, PII in console output

---

4. Privacy & GDPR Compliance

4.1 Mandatory Compliance Webhooks

- [ ] `customers/data_request` **handler** — compile and return all stored data for a customer **(mandatory)**
- [ ] `customers/redact` **handler** — delete/anonymize customer personal data **(mandatory)**
- [ ] `shop/redact` **handler** — delete all customer data for an uninstalled shop (48h after uninstall) **(mandatory)**
- [ ] **All handlers accept POST with JSON body** — `Content-Type: application/json` **(mandatory)**
- [ ] **All handlers validate HMAC** — return 401 for invalid signatures **(mandatory)**
- [ ] **All handlers return 200-series status** — acknowledge receipt **(mandatory)**
- [ ] **Webhook URLs registered in TOML** — `compliance_topics` in `[[webhooks.subscriptions]]`

4.2 Privacy Policy

- [ ] **Privacy policy URL provided** — required for app submission **(mandatory)**
- [ ] **Policy covers what data you collect** — via Shopify APIs and directly from merchants/customers
- [ ] **Policy covers how data is used** — purposes beyond providing app services
- [ ] **Policy covers data retention** — how long you store collected data
- [ ] **Policy covers data storage location** — especially if outside Europe

- ☐ **Policy covers contact information** — how merchants can reach you; physical address if required by jurisdiction

4.3 Data Minimization

- ☐ **Collect only data your app needs** — Shopify reviews for over-collection
- ☐ **Delete data when no longer needed** — honor retention periods
- ☐ **Respond to data subject requests** — within regulatory timeframes (GDPR: 30 days)

---

5. App Store Listing

5.1 Required Information

- ☐ **App name** — unique, not containing "Shopify" or misspellings **(mandatory)**
- ☐ **App icon** — 1200x1200px, JPEG or PNG **(mandatory)**
- ☐ **Primary language** — at least one listing in the primary language **(mandatory)**
- ☐ **App card subtitle** — concise value proposition; no keyword stuffing **(mandatory)**
- ☐ **App details** — clear explanation of functionality with enough feature information **(mandatory)**
- ☐ **Category** — correctly classified; Sales Channels must use Sales Channel category **(mandatory)**
- ☐ **Contact email** — must not contain "Shopify"; API contact email for emergencies **(mandatory)**
- ☐ **Emergency contact** — email and phone number for critical technical issues **(mandatory)**

5.2 Media Assets

- ☐ **Screenshots** — 1600x900px (16:9); 3-6 desktop screenshots minimum **(mandatory)**
- ☐ **Screenshots show actual UI** — no desktop backgrounds, browser windows, or logo-only images **(mandatory)**
- ☐ **Each screenshot is unique** — different features, views, or states; no duplicates **(mandatory)**
- ☐ **No Shopify trademarks in graphics** — not in icon, banner, or screenshots **(mandatory)**
- ☐ **No reviews or testimonials in listing** — Shopify adds reviews from merchant feedback **(mandatory)**
- ☐ **Feature image** — 1600x900px if provided; solid background, good contrast
- ☐ **Demo screencast** — English or English subtitles; shows onboarding + core features **(mandatory)**

5.3 Pricing & Billing

- ☐ **All charges use Shopify Billing API** — no external payment processing for app charges **(mandatory)**
- ☐ **Billing tested with** `"test": true` — verify on dev store without real charges
- ☐ **Change** `"test": false` **before submission** — or merchants won't be charged
- ☐ **Merchants can upgrade/downgrade without reinstalling** — plan changes in-app **(recommended)**
- ☐ **Geographic requirements noted** — if app only works in certain regions **(mandatory if applicable)**

5.4 Submission

- ☐ **Test credentials included** — functional login credentials for reviewers **(mandatory)**

☐ **Demo store URL provided** — link to page demonstrating app functionality **(recommended)**

☐ **Run AI self-review** — available in Partner Dashboard; catches obvious issues pre-submission **(recommended)**

☐ **OAuth install flow tested** — verify redirect URLs work before submitting

---

6. Installation & Onboarding

☐ **App works immediately after install** — no broken states or blank screens **(mandatory)**

☐ **Clear onboarding flow** — guide merchants through setup steps **(recommended)**

☐ **No manual URL entry required** — shop domain is provided by OAuth context **(mandatory)**

☐ **App handles reinstallation** — preserve merchant data or explain what's reset **(mandatory)**

☐ **Clean uninstall** — app doesn't leave orphaned scripts, webhooks, or assets **(recommended)**

---

7. App Functionality & Quality

7.1 Platform Rules

☐ **Use Shopify checkout** — no offsite or third-party checkout bypass **(mandatory)**

☐ **Direct merchants to Shopify Theme Store** — no theme downloads **(mandatory)**

☐ **Factual information only** — no fake reviews, false notifications, or falsified data **(mandatory)**

☐ **Unique app** — not identical to other apps you've published **(mandatory)**

☐ **Single-merchant storefronts only** — marketplaces must be Sales Channels **(mandatory)**

☐ **No upselling in Shopify Admin UI** — don't use admin UI extensions or admin links to promote apps **(mandatory)**

☐ **Max modal requires merchant interaction** — can't auto-launch fullscreen mode **(mandatory)**

7.2 Performance

☐ **App loads quickly** — Shopify measures impact on admin/storefront/checkout performance

☐ **Minimal storefront impact** — if app injects scripts, keep them lightweight

☐ **Test at scale** — verify with realistic data volumes (many customers, orders, products)

7.3 Reliability

☐ **Handle API rate limits** — implement retry with backoff for Shopify API 429 responses

☐ **Handle webhook delivery failures** — idempotent handlers; Shopify retries failed deliveries

☐ **Monitor app health** — webhook delivery rates, function execution, error rates via Dev Dashboard

---

8. Webhooks & Real-Time Sync

- ☐ **Register webhooks via GraphQL** — use `webhookSubscriptionCreate` mutation, not legacy REST
- ☐ **Webhook handlers are idempotent** — same event delivered twice produces same result
- ☐ **Verify HMAC on all webhooks** — Shopify signs payloads with your app secret
- ☐ **Handle webhook payload changes** — new fields may be added; don't fail on unknown fields
- ☐ **Stay within subrequest limits** — Cloudflare Workers: 50 subrequests per invocation
- ☐ **Process webhooks quickly** — respond 200 within 5 seconds; do heavy work asynchronously

---

9. Post-Launch & Maintenance

- ☐ **Keep scopes up to date** — deploy scope changes via `shopify app deploy`
- ☐ **Monitor for new requirements** — Shopify App Excellence Team checks regularly
- ☐ **Respond to review feedback** — new dashboard shows per-requirement status and reviewer comments
- ☐ **Keep API version current** — deprecated versions are removed; migrate before sunset
- ☐ **Keep credentials current** — review test credentials provided to Shopify; update if expired

- [ ] **App reflects listed functionality** — apps re-evaluated if core functionality changes

Quick Reference: Key Dates

DATE	REQUIREMENT
Feb 2025	Scopes reviewed for necessity on every submission
Dec 2025	Protected customer data scopes enforced for web pixels
Dec 2025	Expiring offline tokens available (optional)
Apr 1, 2026	**Expiring offline tokens mandatory for new public apps**
Mar 2026	RBAC and org management for partners
Mar 2026	Clearer image standards enforced (4.4.4, 4.4.5)
Apr 2026	New app submission experience in Partner Dashboard

Resources

- App Store Requirements
- Best Practices for Apps
- Protected Customer Data
- Expiring Offline Tokens
- Privacy Requirements

- Dev Dashboard
- Migrate from Partner Dashboard
- Submit App for Review
- About Billing
- AI Self-Review Tool

Last updated: May 2026. Requirements are subject to change — always check shopify.dev for the latest.
